ASSETTRUST v0.44

Secure Password Recovery | Implementation Review and Release Verdict

NO-GO - NOT PRODUCTION READY

The v0.44 milestone adds a password-recovery flow to the existing AssetTrust identity system. It is designed to limit credential exposure and account enumeration, preserve administrator MFA, and revoke old sessions when a password is reset. This assessment covers source-code changes and offline verification only.

Scope and security outcome

Item	Result
Baseline	AssetTrust v0.43 security checkpoint
New feature	One-time 15-minute recovery token, server-only HTTPS relay adapter and PostgreSQL-shared request throttling
Offline engineering	16 of 16 new tests and 42 of 42 version commands passed
Security outcome	Application source improved; no production deployment authorized

What changed in source

- **Random reset tokens:** 32 cryptographically secure random bytes encoded as URL-safe text. Only SHA-256 token hashes are stored in PostgreSQL.
- **Time-bound and single-use:** database-generated 15-minute expiry, one active reset request per account, locked consumption and replay denial.
- **Server delivery:** dedicated HTTPS-only relay adapter. Private relay credentials remain server-side; redirects are forbidden and delivery has a finite timeout.
- **Account protection:** fresh Argon2id password hash, validation and password-reuse check, all login sessions and pending MFA-login challenges invalidated.

Important qualification

The outbound email relay is an adapter contract, not an activated or independently verified provider. Without valid server-side relay settings, password recovery is unavailable. The offline test suite uses mocks for database, Argon2 and external delivery; those results must not be confused with real delivery, live database races, or a complete authenticated browser journey.

Security controls and boundaries

Controls added to v0.44 are listed separately from deployment guarantees.

Control	Design	Verification
Reset token	256-bit random, canonical base64url, hash at rest	Domain tests PASS
Expiry and reuse	15-minute DB expiry; locked, one-use transaction	Unit tests PASS; DB pending
Request abuse	3 per-email requests per hour using keyed HMAC identity	Unit tests PASS; DB pending
Account privacy	Same generic request result for existing, absent or limited email	Mock service tests PASS
Mail delivery	Approved HTTPS relay, no redirects, private credentials	Adapter tests PASS; provider pending
Password and session	New Argon2id hash; session/challenge revocation	Mock tests PASS; live pending
Browser/CSRF	Origin-checked POST; URL fragment removed from history	Source tests PASS; browser pending
Audit event	Organization-scoped PASSWORD_RESET_COMPLETED	Mock test PASS; live pending
Migration	019_password_reset.sql; checksummed forward-only	19/19 source hashes match

Remaining risk

A mailbox reset proves control of an email inbox, not identity ownership or legal rights over land and assets. Existing MFA enrollment is preserved by design, and privileged access still requires MFA where configured. Shared request throttles limit attacks against an email identity, but a distributed infrastructure-level abuse strategy and careful cleanup/retention of rate-limit records remain necessary.

Test evidence and release blockers

Tests actually executed

Validation	Evidence
New v0.44 offline tests	16/16 PASS
Legacy plus new version checks	42/42 PASS (v0.03-v0.44)
Architecture contracts	PASS
TS/TSX syntax scan	98 files, zero syntax diagnostics; not a typecheck
Current-tree secret scanner	0 matches in about 1,600 inspected text/source files; limited patterns
Migration fingerprints	19/19 exact SHA-256 matches

Release blockers - action required

- **Build integrity:** authentic reviewed npm lockfile, clean npm ci, full tests/typechecks/builds, dependency audit, SBOM and vulnerable/unused package remediation.
- **Live PostgreSQL:** run migration 019 and guarded contract test on a disposable database, verify parallel reset attempts and transaction rollback, then rehearse upgrade/restore.
- **Email provider:** install and prove the HTTPS relay and endpoint identity, validate delivery, failure, monitoring, token handling and egress restrictions.
- **Browser and security:** automated account recovery and MFA flows, cross-origin and CSRF negatives, no credential capture by analytics/proxies/logs.
- **Platform hardening:** independently verify tenant database restrictions, server input validation, login abuse limits, safe uploads, admin RBAC, server-authoritative prices and actual HTTPS.
- **Git and infrastructure:** scan full canonical Git history, rotate confirmed leaked secrets at providers, validate firewalls/SSH, disaster recovery and secrets custody.

Explicit test limitations

No live PostgreSQL, installed Node workspaces, full API/React builds, browser automation against a running deployment, provider key rotation, email relay or network firewall changes were performed in this environment. The release preflight remains blocked, as designed.

Handover and approval gate

Kali Linux validation - safe sequence

Use a dedicated test database, fresh test credentials and a reviewed dependency lockfile. Do not run mutating suites against production.

```
npm run verify:v44

npm run verify:ci:v41

npm run verify:architecture && npm run verify:syntax

npm run security:scan:v43

npm install --package-lock-only --ignore-scripts # review before commit

npm ci && npm audit --omit=dev --audit-level=high

npm test && npm run build

npm run db:migrate && npm run db:check

NODE_ENV=test ASSETTRUST_E2E_ALLOW_MUTATION=YES npm run test:pg:reset:v44
```

Server-only relay configuration

Configure PASSWORD_RESET_RELAY_URL, PASSWORD_RESET_RELAY_TOKEN, PASSWORD_RESET_PUBLIC_ORIGIN, PASSWORD_RESET_LOOKUP_PEPPER, and matching WEB_ORIGIN in a trusted server-side secret manager. The relay is not enabled by this artifact and must be independently verified before serving real account recovery requests.

Cross-project security policy

The mandatory FINAL SECURITY HARDENING AND RELEASE GATE from v0.43 remains required for AssetTrust, NETOLA, Farmer's Pride, Campus Live, BursarPro, and all future software projects, including Codex and Claude handovers. No release is approved by a source scan or a green offline regression count alone.

Final recommendation

HOLD PRODUCTION RELEASE. Verify the live password recovery workflow and the full security gate on a hardened deployment, independently review critical/high findings, and record artifacts before any commercial customer data is accepted. See V44_KALI_VALIDATION.md and V44_SECURITY_REPORT.md for the full checklist.